

Tài liệu kiểm thử – Module Authentication

Dự án: Homi Hotel Booking
Module: Auth API
Ngày cập nhật: 2026-06-12
Người thực hiện: (điền tên)
Môi trường: Laravel 13 · Sanctum · SQLite in-memory (test)

1. Phạm vi kiểm thử

Nhóm	Endpoint	Method	Auth
Đăng ký	/api/v1/register	POST	Không
Đăng nhập	/api/v1/login	POST	Không
Xem hồ sơ	/api/v1/me	GET	Cần token
Cập nhật hồ sơ	/api/v1/profile	PUT	Cần token
Đổi mật khẩu	/api/v1/change-password	PUT	Cần token
Đăng xuất	/api/v1/logout	POST	Cần token

Cấu trúc response chuẩn:

```
{
  "success": true | false,
  "message": "...",
  "data": { ... },
  "errors": { "field": ["..."] }
}
```

2. Cài đặt môi trường kiểm thử

```
# Chạy toàn bộ test auth
php artisan test --filter=Auth

# Chạy từng nhóm
php artisan test tests/Feature/Auth/RegisterTest.php
php artisan test tests/Feature/Auth/LoginTest.php
php artisan test tests/Feature/Auth/ProfileTest.php
php artisan test tests/Feature/Auth/RbacTest.php
```

```
# Chạy tất cả với output chi tiết
php artisan test --filter=Auth --verbose
```

Lưu ý: Các test dùng `RefreshDatabase` — database được reset sau mỗi test, không ảnh hưởng dữ liệu thực.

3. Test Cases – Đăng ký (`/api/v1/register`)

TC-REG-01 – Đăng ký thành công với đầy đủ thông tin

Mục tiêu	Tạo tài khoản mới với đầy đủ các trường hợp lệ
Method / URL	POST <code>/api/v1/register</code>
Input	<code>name: "Nguyễn Văn A" · email: "test@homi.vn" · phone: "0901234567" · address: "Hà Nội" · password: "123456" · password_confirmation: "123456"</code>
Expected HTTP	201 Created
Expected Body	<code>success: true</code> · có <code>data.user</code> và <code>data.token</code>
Kiểm tra DB	Bảng <code>users</code> có bản ghi <code>email=test@homi.vn, role=customer</code>
File test	<code>RegisterTest::test_register_success_with_full_data</code>
Kết quả	✅ Pass

TC-REG-02 – Đăng ký thành công không có phone/address

Mục tiêu	Xác nhận <code>phone</code> và <code>address</code> là tùy chọn
Method / URL	POST <code>/api/v1/register</code>
Input	<code>name: "Nguyễn Văn B" · email: "b@homi.vn" · password: "123456" · password_confirmation: "123456"</code>
Expected HTTP	201 Created
Expected Body	<code>success: true</code>
File test	<code>RegisterTest::test_register_success_without_optional_fields</code>
Kết quả	✅ Pass

TC-REG-03 – Đăng ký thất bại – Email đã tồn tại

Mục tiêu	Ngăn trùng lặp email trong hệ thống
Method / URL	POST /api/v1/register
Input	Gửi lần 2 cùng email: "dup@homi.vn"
Expected HTTP	422 Unprocessable Entity
Expected Body	success: false · errors.email chứa thông báo lỗi
Thông báo lỗi	"Email đã được sử dụng."
File test	RegisterTest::test_register_fails_with_duplicate_email
Kết quả	✔ Pass

TC-REG-04 – Đăng ký thất bại – Thiếu trường bắt buộc

Mục tiêu	Validate các trường bắt buộc: name, email, password
Method / URL	POST /api/v1/register
Input	Body rỗng {}
Expected HTTP	422 Unprocessable Entity
Expected Body	errors có key name, email, password
File test	RegisterTest::test_register_fails_when_required_fields_missing
Kết quả	✔ Pass

TC-REG-05 – Đăng ký thất bại – Email sai định dạng

Mục tiêu	Validate định dạng email hợp lệ
Method / URL	POST /api/v1/register
Input	email: "not-an-email"
Expected HTTP	422 Unprocessable Entity
Expected Body	errors.email có lỗi
Thông báo lỗi	"Email không đúng định dạng."
File test	RegisterTest::test_register_fails_with_invalid_email_format
Kết quả	✔ Pass

TC-REG-06 – Đăng ký thất bại – Mật khẩu xác nhận không khớp

Mục tiêu	Phát hiện khi <code>password</code> $\neq$ <code>password_confirmation</code>
Method / URL	<code>POST /api/v1/register</code>
Input	<code>password: "123456" · password_confirmation: "wrong"</code>
Expected HTTP	<code>422 Unprocessable Entity</code>
Expected Body	<code>errors.password</code> có lỗi
Thông báo lỗi	"Xác nhận mật khẩu không khớp."
File test	<code>RegisterTest::test_register_fails_when_password_confirmation_mismatch</code>
Kết quả	 Pass

TC-REG-07 – Đăng ký thất bại – Mật khẩu quá ngắn

Mục tiêu	Enforce độ dài tối thiểu 6 ký tự
Method / URL	<code>POST /api/v1/register</code>
Input	<code>password: "123" · password_confirmation: "123"</code>
Expected HTTP	<code>422 Unprocessable Entity</code>
Expected Body	<code>errors.password</code> có lỗi
Thông báo lỗi	"Mật khẩu phải có ít nhất 6 ký tự."
File test	<code>RegisterTest::test_register_fails_when_password_too_short</code>
Kết quả	 Pass

TC-REG-08 – Mật khẩu không lộ trong response

Mục tiêu	Bảo mật: trường <code>password</code> không được trả về cho client
Method / URL	<code>POST /api/v1/register</code>
Input	Đăng ký hợp lệ
Expected HTTP	<code>201 Created</code>
Expected Body	<code>data.user</code> không chứa key <code>password</code>
File test	<code>RegisterTest::test_password_not_exposed_in_response</code>
Kết quả	 Pass

4. Test Cases – Đăng nhập (`/api/v1/login`)

TC-LOGIN-01 – Đăng nhập thành công

Mục tiêu	Trả về token khi thông tin hợp lệ
Method / URL	POST /api/v1/login
Input	email: "user@homi.vn" · password: "123456"
Tiền điều kiện	Tài khoản tồn tại, status=active
Expected HTTP	200 OK
Expected Body	success: true · có data.user và data.token
File test	LoginTest::test_login_success_returns_token
Kết quả	✓ Pass

TC-LOGIN-02 – Đăng nhập thất bại – Sai mật khẩu

Mục tiêu	Từ chối khi mật khẩu không khớp
Method / URL	POST /api/v1/login
Input	email: "user@homi.vn" · password: "sai_mat_khau"
Expected HTTP	401 Unauthorized
Expected Body	success: false · message: "Email hoặc mật khẩu không đúng."
File test	LoginTest::test_login_fails_with_wrong_password
Kết quả	✓ Pass

TC-LOGIN-03 – Đăng nhập thất bại – Email không tồn tại

Mục tiêu	Từ chối khi email chưa đăng ký
Method / URL	POST /api/v1/login
Input	email: "khongtontai@homi.vn" · password: "123456"
Expected HTTP	401 Unauthorized
Expected Body	success: false
Lưu ý bảo mật	Thông báo lỗi không tiết lộ email có tồn tại hay không
File test	LoginTest::test_login_fails_with_nonexistent_email
Kết quả	✓ Pass

TC-LOGIN-04 – Đăng nhập thất bại – Tài khoản bị khóa

Mục tiêu	Chặn truy cập khi tài khoản status=locked
----------	---

Method / URL	POST /api/v1/login
Input	email: "user@homi.vn" · password: "123456"
Tiền điều kiện	Tài khoản có status=locked
Expected HTTP	403 Forbidden
Expected Body	success: false · message: "Tài khoản đã bị khóa."
File test	LoginTest::test_login_fails_when_account_is_locked
Kết quả	✓ Pass

TC-LOGIN-05 – Đăng nhập thất bại – Thiếu trường bắt buộc

Mục tiêu	Validate email và password là bắt buộc
Method / URL	POST /api/v1/login
Input	Body rỗng {}
Expected HTTP	422 Unprocessable Entity
Expected Body	errors có key email và password
File test	LoginTest::test_login_fails_when_fields_missing
Kết quả	✓ Pass

TC-LOGIN-06 – Mật khẩu không lộ trong response đăng nhập

Mục tiêu	Bảo mật: password không được trả về sau khi đăng nhập
Method / URL	POST /api/v1/login
Input	Đăng nhập hợp lệ
Expected HTTP	200 OK
Expected Body	data.user không chứa key password
File test	LoginTest::test_password_not_in_login_response
Kết quả	✓ Pass

5. Test Cases – Đăng xuất (/api/v1/logout)

TC-LOGOUT-01 – Đăng xuất thành công

Mục tiêu	Thu hồi token hiện tại, kết thúc phiên đăng nhập
-----------------	--

Method / URL	POST /api/v1/logout
Header	Authorization: Bearer {token}
Tiền điều kiện	Đã đăng nhập, token hợp lệ
Expected HTTP	200 OK
Expected Body	success: true · message: "Đăng xuất thành công."
Sau khi thực hiện	Token bị xóa, không dùng được nữa
File test	ProfileTest::test_logout_success
Kết quả	✓ Pass

TC-LOGOUT-02 – Đăng xuất thất bại – Chưa đăng nhập

Mục tiêu	Middleware auth:sanctum chặn request không có token
Method / URL	POST /api/v1/logout
Header	Không có Authorization
Expected HTTP	401 Unauthorized
File test	ProfileTest::test_logout_requires_authentication
Kết quả	✓ Pass

6. Test Cases – Xem hồ sơ (/api/v1/me)

TC-ME-01 – Xem thông tin tài khoản thành công

Mục tiêu	Trả về thông tin user đang đăng nhập
Method / URL	GET /api/v1/me
Header	Authorization: Bearer {token}
Expected HTTP	200 OK
Expected Body	data.user.email khớp với email của user
File test	ProfileTest::test_me_returns_authenticated_user
Kết quả	✓ Pass

TC-ME-02 – Xem hồ sơ thất bại – Chưa đăng nhập

Mục tiêu	Chặn truy cập khi không có token
-----------------	----------------------------------

Method / URL	GET /api/v1/me
Expected HTTP	401 Unauthorized
File test	ProfileTest::test_me_requires_authentication
Kết quả	 Pass

7. Test Cases – Cập nhật hồ sơ (/api/v1/profile)

TC-PROFILE-01 – Cập nhật hồ sơ thành công

Mục tiêu	Cập nhật thông tin cá nhân hợp lệ
Method / URL	PUT /api/v1/profile
Header	Authorization: Bearer {token}
Input	name: "Tên Mới" · email: "new@homi.vn" · phone: "0909090909" · address: "TP HCM"
Expected HTTP	200 OK
Expected Body	data.user.name = "Tên Mới" · data.user.email = "new@homi.vn"
Kiểm tra DB	Bảng users có email=new@homi.vn
File test	ProfileTest::test_update_profile_success
Kết quả	 Pass

TC-PROFILE-02 – Cập nhật thất bại – Thiếu trường bắt buộc

Mục tiêu	Validate name và email là bắt buộc khi cập nhật
Method / URL	PUT /api/v1/profile
Input	Body rỗng {}
Expected HTTP	422 Unprocessable Entity
Expected Body	errors có key name và email
File test	ProfileTest::test_update_profile_fails_when_required_fields_missing
Kết quả	 Pass

TC-PROFILE-03 – Cập nhật thất bại – Email trùng user khác

Mục tiêu	Ngăn cập nhật sang email đã thuộc về tài khoản khác
Method / URL	PUT /api/v1/profile

Tiền điều kiện	User A có <code>email=taken@homi.vn</code> ; User B đang cập nhật
Input	<code>name: "Test" · email: "taken@homi.vn"</code>
Expected HTTP	<code>422 Unprocessable Entity</code>
Expected Body	<code>errors.email</code> có lỗi
File test	<code>ProfileTest::test_update_profile_fails_when_email_taken_by_another_user</code>
Kết quả	✅ Pass

TC-PROFILE-04 – Cập nhật thành công giữ nguyên email

Mục tiêu	Rule <code>unique</code> bỏ qua chính user hiện tại (ignore self)
Method / URL	<code>PUT /api/v1/profile</code>
Input	<code>name: "New Name" · email: "user@homi.vn"</code> (email không đổi)
Expected HTTP	<code>200 OK</code>
Lý do quan trọng	Nếu không có <code>Rule::unique(...)->ignore()</code> sẽ báo lỗi sai
File test	<code>ProfileTest::test_update_profile_allows_keeping_same_email</code>
Kết quả	✅ Pass

8. Test Cases – Đổi mật khẩu (`/api/v1/change-password`)

TC-CHPW-01 – Đổi mật khẩu thành công

Mục tiêu	Thay đổi mật khẩu và thu hồi toàn bộ token cũ
Method / URL	<code>PUT /api/v1/change-password</code>
Input	<code>current_password: "123456" · password: "newpass123" · password_confirmation: "newpass123"</code>
Expected HTTP	<code>200 OK</code>
Expected Body	<code>success: true</code>
Kiểm tra DB	<code>Hash::check('newpass123', user->fresh()->password) = true</code>
Sau khi thực hiện	Tất cả token bị xóa (buộc đăng nhập lại)
File test	<code>ProfileTest::test_change_password_success</code>
Kết quả	✅ Pass

TC-CHPW-02 – Đổi mật khẩu thất bại – Mật khẩu hiện tại sai

Mục tiêu	Từ chối khi <code>current_password</code> không khớp với DB
Method / URL	<code>PUT /api/v1/change-password</code>
Input	<code>current_password: "sai_roi" · password: "newpass123" · password_confirmation: "newpass123"</code>
Expected HTTP	<code>422 Unprocessable Entity</code>
Expected Body	<code>success: false</code>
File test	<code>ProfileTest::test_change_password_fails_with_wrong_current_password</code>
Kết quả	 Pass

TC-CHPW-03 – Đổi mật khẩu thất bại – Xác nhận không khớp

Mục tiêu	Validate <code>password_confirmation</code> phải khớp <code>password</code>
Method / URL	<code>PUT /api/v1/change-password</code>
Input	<code>current_password: "123456" · password: "newpass123" · password_confirmation: "khac"</code>
Expected HTTP	<code>422 Unprocessable Entity</code>
Expected Body	<code>errors.password</code> có lỗi
File test	<code>ProfileTest::test_change_password_fails_when_confirmation_mismatch</code>
Kết quả	 Pass

9. Test Cases – Phân quyền / RBAC

TC-RBAC-01 – Customer truy cập hồ sơ của chính mình

Method / URL	<code>GET /api/v1/me</code>
Tiền điều kiện	Đăng nhập với <code>role=customer</code>
Expected HTTP	<code>200 OK</code>
Expected Body	<code>data.user.role = "customer"</code>

File test	RbacTest::test_customer_can_access_own_profile
Kết quả	 Pass

TC-RBAC-02 – Staff truy cập hồ sơ của chính mình

Tiền điều kiện	Đăng nhập với <code>role=staff</code>
Expected Body	<code>data.user.role = "staff"</code>
File test	RbacTest::test_staff_can_access_own_profile
Kết quả	 Pass

TC-RBAC-03 – Admin truy cập hồ sơ của chính mình

Tiền điều kiện	Đăng nhập với <code>role=admin</code>
Expected Body	<code>data.user.role = "admin"</code>
File test	RbacTest::test_admin_can_access_own_profile
Kết quả	 Pass

TC-RBAC-04 – Tài khoản bị khóa không đăng nhập được

Mục tiêu	<code>status=locked</code> bị chặn ở tầng login
Expected HTTP	<code>403 Forbidden</code>
File test	RbacTest::test_inactive_account_cannot_login
Kết quả	 Pass

TC-RBAC-05 – Request không có token bị từ chối 401

Mục tiêu	Tất cả endpoint cần auth đều yêu cầu token hợp lệ
Endpoints kiểm tra	<code>GET /me · PUT /profile · PUT /change-password · POST /logout</code>
Expected HTTP	<code>401 Unauthorized</code> cho tất cả
File test	RbacTest::test_unauthenticated_request_returns_401
Kết quả	 Pass

TC-RBAC-06 – Người dùng đăng ký mới nhận role mặc định `customer`

Mục tiêu	Hệ thống không cho phép tự chọn role khi đăng ký
----------	--

Expected Body	<code>data.user.role = "customer"</code>
File test	<code>RbacTest::test_newly_registered_user_has_customer_role</code>
Kết quả	 Pass

TC-RBAC-07 – Token đã thu hồi bị từ chối 401

Mục tiêu	Token không còn trong DB phải bị từ chối
Luồng	Tạo token → xóa token trong DB → gửi request với token đó
Expected HTTP	<code>401 Unauthorized</code>
File test	<code>RbacTest::test_revoked_token_returns_401</code>
Kết quả	 Pass

10. Tổng kết

Nhóm	Số TC	Pass	Fail
Đăng ký	8	8	0
Đăng nhập	6	6	0
Đăng xuất	2	2	0
Xem hồ sơ (me)	2	2	0
Cập nhật hồ sơ	4	4	0
Đổi mật khẩu	3	3	0
Phân quyền RBAC	7	7	0
Tổng	32	32	0

Kết quả xác thực bằng lệnh: `php artisan test --filter=Auth` → **35 tests, 35 passed** (bao gồm `ExampleTest` và `HealthCheckTest`).

Điểm cần lưu ý

- **Bảo mật:** Trường `password` bị ẩn qua `$hidden` trong `User` model — đã được kiểm tra ở TC-REG-08 và TC-LOGIN-06.
- **Unique email ignore-self:** `UpdateProfileRequest` dùng `Rule::unique()->ignore($id)` — quan trọng, đã kiểm tra TC-PROFILE-04.
- **Token lifecycle:** Đổi mật khẩu thu hồi toàn bộ token — đã kiểm tra TC-CHPW-01.
- **Status check:** Kiểm tra `locked` sau khi xác thực password để tránh timing leak — đã kiểm tra TC-LOGIN-04 và TC-RBAC-04.